

Jour 1

1. Introduction

Dans le cadre de cet audit, X-corp - entreprise éditrice de solutions logicielles de gestion de données et de marketing digital - doit être évaluée sur sa conformité au Règlement Général sur la Protection des Données (RGPD). Elle manipule des données particulièrement sensibles : historiques médicaux via HealthMed, données d'achat via RetailCo, comportements d'apprentissage via EduLearn. Ce rapport pose les bases théoriques nécessaires avant l'audit proprement dit (registre des traitements, DPIA, gestion de violation, audit de conformité).

2. Qu'est-ce que le RGPD ?

Le RGPD est un règlement européen entré en application le 25 mai 2018. Contrairement à une directive, il s'applique directement et de façon identique dans tous les États membres, sans nécessiter de loi de transposition nationale, ce qui en fait un texte particulièrement contraignant et harmonisé à l'échelle de l'Union européenne. Il remplace un ensemble de législations nationales disparates par un cadre unique, plus exigeant, adapté à une économie numérique où les données circulent sans frontière.

Son objectif est de redonner aux citoyens le contrôle sur leurs données personnelles, tout en responsabilisant les organisations qui les traitent ; c'est le principe d'*accountability* : être conforme, mais aussi capable de le prouver à tout moment, notamment via une documentation adaptée (registre des traitements, DPIA, preuves de consentement).

Le RGPD s'applique à toute organisation traitant des données de résidents européens, même établie hors UE : c'est ce qu'on appelle son **champ d'application extraterritorial**. Pour X-corp : un client de DataManage basé hors UE resterait soumis au RGPD dès qu'il traiterait des données de citoyens européens, tout comme X-corp elle-même reste concernée pour l'ensemble de ses traitements réalisés depuis son siège parisien.

3. Notions clés

Une **donnée à caractère personnel** est toute information permettant d'identifier une personne, directement ou indirectement (nom, email, mais aussi un identifiant utilisateur croisé avec d'autres données). Une **donnée sensible** (santé, origine ethnique, opinions politiques...) bénéficie d'une protection renforcée - c'est le cas des données médicales traitées pour HealthMed.

Le **traitement** désigne toute opération sur des données (collecte, stockage, analyse, suppression...). X-corp est **responsable de traitement** pour ses propres besoins, mais agit aussi comme **sous-traitant** vis-à-vis de ses clients (RetailCo, HealthMed, EduLearn), puisqu'elle traite leurs données pour leur compte. Cette distinction est centrale : le responsable de traitement décide des finalités et moyens, le sous-traitant exécute selon ses instructions.

Enfin, la **personne concernée** est l'individu dont les données sont traitées (le client de RetailCo, le patient de HealthMed), le **DPO** (Data Protection Officer) supervise la conformité en interne, et la **CNIL** est l'autorité de contrôle française.

4. Les grands principes (article 5 du RGPD)

L'article 5 du RGPD pose six principes fondamentaux, socle sur lequel repose toute la logique du règlement.

Le premier est la **licéité, loyauté et transparence** : un traitement doit reposer sur une base légale valide et être compréhensible pour la personne concernée. La **limitation des finalités** interdit de réutiliser des données pour un autre usage que celui annoncé ; les données EduLearn collectées pour le suivi pédagogique ne devraient pas servir au marketing sans nouveau consentement.

La **minimisation** impose de ne collecter que le strictement nécessaire, et l'**exactitude** de maintenir les données à jour ; un enjeu sensible pour les données médicales de HealthMed. La **limitation de la conservation** interdit de garder les données indéfiniment : X-corp applique déjà des durées différenciées (5 ans pour RetailCo, 10 ans pour HealthMed, 2 ans pour EduLearn).

Enfin, l'**intégrité et confidentialité** exige des mesures de protection adaptées : chiffrement AES-256, authentification à deux facteurs, contrôle d'accès par rôles (RBAC) sont déjà en place chez X-corp. Ces six principes s'articulent entre eux, et c'est leur respect cohérent qui permettra, dans les jours suivants, de bâtir un registre des traitements fidèle à la pratique réelle de l'entreprise.

5. Les bases légales (article 6)

Pour qu'un traitement soit licite, il doit reposer sur l'une des six bases légales prévues par le RGPD : consentement, exécution d'un contrat, obligation légale, sauvegarde des intérêts vitaux, mission d'intérêt public, ou intérêt légitime. Le choix de la base légale n'est pas neutre : il détermine les droits dont dispose la personne concernée, seul le consentement, par exemple, permet un retrait à tout moment, ce qui n'est pas le cas pour une obligation légale.

X-corp s'appuie principalement sur le **consentement** pour ses trois traitements (RetailCo, HealthMed, EduLearn). Pour être valable, celui-ci doit être libre, spécifique, éclairé et révocable aussi facilement qu'il a été donné ; quatre conditions cumulatives, et non de simples recommandations. C'est justement sur ce point que X-corp rencontre des difficultés, le document signalant des problèmes récurrents pour gérer et documenter le consentement lié aux campagnes AutoMail, ce qui constitue un point d'attention pour l'audit à venir.

6. Les droits des personnes concernées

Le RGPD confère aux individus plusieurs droits opposables aux organisations : accès (obtenir une copie de ses données), rectification, effacement, opposition (notamment à la prospection commerciale), portabilité, et limitation du traitement. Chaque demande doit en principe recevoir une réponse dans un délai d'un mois.

Ce volet est loin d'être théorique pour X-corp : l'entreprise reçoit entre 50 et 100 demandes de droit d'accès par mois, un volume qui impose un processus rodé - et qui pose la question

de savoir qui traite ces demandes, avec quel outil, et comment l'identité du demandeur est vérifiée avant toute communication de données.

7. Les obligations de l'entreprise

Au-delà des principes, le RGPD impose des obligations concrètes destinées à démontrer la conformité. La première est la tenue d'un **registre des traitements**, recensant chaque activité (finalité, données, durée de conservation, sécurité). La deuxième est la réalisation d'une **DPIA** pour tout traitement à risque élevé, notamment dès que des données de santé sont en jeu, comme pour HealthMed.

La troisième est la **notification des violations de données** : en cas de fuite, la CNIL doit être informée sous 72h, et les personnes concernées si le risque est élevé ; un point d'autant plus concret pour X-corp qu'une fuite a déjà exposé 2 000 enregistrements clients il y a un an, révélant des lacunes dans le processus de réponse. Enfin, la désignation d'un **DPO** est obligatoire dès lors qu'un traitement à grande échelle de données sensibles a lieu, ce qui est déjà le cas chez X-corp.

8. Conclusion

Ce panorama théorique montre que X-corp n'est pas une entreprise négligente : chiffrement AES-256, authentification à deux facteurs, contrôle d'accès par rôles, DPO nommé, DPIA réalisées avant chaque lancement ; le socle est réel. Mais plusieurs zones de fragilité ressortent déjà : la documentation du consentement marketing, le volume des demandes de droit d'accès, et les lacunes révélées par l'incident de fuite passé.

Ce sont précisément ces points que la suite de l'audit permettra d'objectiver : le registre des traitements (Jour 2) formalisera une vision exhaustive des pratiques, la DPIA (Jour 3) évaluera le risque réel d'un traitement, la simulation de violation (Jour 4) testera la réactivité du processus, et l'audit final (Jour 5) dressera le bilan global de conformité.

Jour 2

Registre des traitements — Fiche n°1 : Gestion des Clients (RetailCo)

Champ	Détail
Nom du traitement	Gestion des clients RetailCo
Responsable de traitement	RetailCo (X-corp agit comme sous-traitant via DataManage)
Finalité(s)	Personnalisation des offres et promotions, amélioration de l'expérience client
Base légale	Consentement des clients
Catégorie de données	Noms, adresses, emails, numéros de téléphone, historique d'achats, préférences de produits
Catégories de personnes concernées	Clients de RetailCo (particuliers)
Destinataires	Équipes marketing de RetailCo, personnel X-corp habilité (accès RBAC), sous-traitant CloudSecure (hébergement)
Durée de conservation	5 ans après le dernier contact
Mesures de sécurité	Chiffrement AES-256 (transit/repos), authentification à deux facteurs, contrôle d'accès basé sur les rôles, pseudonymisation
Transferts hors UE	À vérifier - dépend de la localisation des serveurs CloudSecure (à documenter dans l'audit)

Jour 3

Jour 3 — DPIA : Suivi des Patients (HealthMed)

1. Description du traitement

Nature du traitement : Ce traitement consiste en la collecte, le stockage et l'analyse des données de patients dans le cadre du service DataManage de X-corp, pour le compte de son client HealthMed, société de services de santé. X-corp intervient ici en tant que sous-traitant : c'est HealthMed qui définit les finalités du traitement, X-corp se chargeant de l'infrastructure technique et de l'exploitation des données.

Portée : Il s'agit d'un traitement à **grande échelle**, puisqu'il concerne environ 500 000 patients. Cette ampleur est un critère à part entière justifiant la réalisation d'une DPIA, indépendamment même de la sensibilité des données traitées.

Contexte : Les données sont hébergées via CloudSecure, partenaire technologique de X-corp spécialisé dans le stockage sécurisé en cloud. Ce point est important dans le cadre d'une DPIA, car il introduit un tiers supplémentaire dans la chaîne de traitement, avec ses propres garanties de sécurité à documenter.

Finalités : Le traitement poursuit trois objectifs distincts : le suivi des traitements médicaux des patients, le rappel de leurs rendez-vous, et la personnalisation des conseils de santé qui leur sont adressés. Ces trois finalités, bien que liées, mériteraient chacune d'être clairement identifiées afin de respecter le principe de limitation des finalités vu en Jour 1.

Données traitées : Le traitement porte sur des noms, adresses, emails, numéros de téléphone, mais surtout sur l'historique médical et les prescriptions des patients. Ces deux dernières catégories constituent des **données de santé**, qui appartiennent à la catégorie des données dites « sensibles » au sens de l'article 9 du RGPD - une catégorie bénéficiant d'un régime de protection renforcé, ce qui justifie à elle seule l'obligation de réaliser une DPIA.

Base légale : Le traitement repose sur le **consentement explicite** des patients. Cette exigence est plus stricte que le consentement « simple » requis pour des données ordinaires : pour des données de santé, l'article 9 impose un consentement explicite, c'est-à-dire une action positive et non ambiguë de la personne, allant au-delà d'une simple case cochée.

Durée de conservation : Les données sont conservées 10 ans après la fin du traitement médical, une durée cohérente avec les obligations de conservation propres au secteur de la santé.

2. Évaluation de la nécessité et de la proportionnalité

Le traitement est-il nécessaire à la finalité poursuivie ? Le suivi des traitements médicaux et le rappel des rendez-vous nécessitent effectivement l'accès à l'historique médical et aux coordonnées du patient ; sans ces données, HealthMed ne pourrait tout simplement pas assurer un suivi personnalisé. En revanche, la finalité de « personnalisation des conseils de santé » mérite d'être questionnée : s'agit-il de recommandations générées automatiquement à partir de l'historique médical (ce qui pose la question d'un éventuel

profilage), ou de conseils formulés par un professionnel de santé sur la base du dossier ? Cette distinction devra être clarifiée avec HealthMed, car elle conditionne le niveau de risque du traitement.

Le traitement est-il proportionné ? Les données collectées (noms, adresses, emails, téléphone, historique médical, prescriptions) semblent correspondre au principe de minimisation vu en Jour 1 : aucune donnée superflue n'apparaît dans la description fournie. Il conviendrait toutefois de vérifier, lors de l'audit, si l'intégralité de l'historique médical est réellement nécessaire pour les trois finalités visées, ou si un accès plus restreint (par exemple limité aux traitements en cours) suffirait pour les rappels de rendez-vous.

Les mesures garantissant les droits des personnes sont-elles adéquates ? Le consentement explicite constitue la première garantie, à condition qu'il soit recueilli, documenté et révocable dans les mêmes conditions que pour les autres traitements de X-corp — un point qu'on a déjà identifié comme fragile en Jour 1 pour les campagnes marketing, et qu'il convient de vérifier spécifiquement ici, sur un traitement à plus fort enjeu. Le droit d'accès et de rectification, essentiel pour des données médicales potentiellement obsolètes, doit également pouvoir s'exercer facilement - le volume de 50 à 100 demandes mensuelles évoqué dans le document laisse penser qu'un processus existe déjà, mais sa robustesse spécifique aux données de santé reste à confirmer.

3. Étude des risques sur les droits et libertés

Cette dernière partie identifie les risques principaux qui pèsent sur les données des patients, en évaluant pour chacun sa **gravité** (l'ampleur des conséquences pour la personne) et sa **vraisemblance** (la probabilité que le risque se réalise), avant de recenser les mesures déjà en place et celles qu'il conviendrait d'ajouter.

Risque n°1 — Accès illégitime aux données

Un accès non autorisé à l'historique médical ou aux prescriptions d'un patient constituerait une atteinte grave à sa vie privée, avec des conséquences potentiellement lourdes (discrimination, stigmatisation, atteinte à la réputation). La **gravité** est donc élevée, tandis que la **vraisemblance** est limitée par les mesures déjà en place chez X-corp : authentification à deux facteurs et contrôle d'accès basé sur les rôles (RBAC), qui restreignent l'accès aux seuls employés habilités. Une mesure complémentaire pertinente serait la mise en place d'une journalisation systématique des accès aux dossiers médicaux, permettant de tracer qui consulte quelles données et à quel moment.

Risque n°2 — Modification ou altération non désirée des données

Une modification erronée de l'historique médical ou des prescriptions pourrait avoir des conséquences directes sur la santé du patient (erreur de traitement, prescription inadaptée). La gravité est donc particulièrement élevée dans ce contexte médical. La vraisemblance reste toutefois modérée grâce au chiffrement des données et aux contrôles d'accès existants. Un mécanisme de vérification d'intégrité et un historique des modifications (traçabilité des versions) renforceraient la protection contre ce risque.

Risque n°3 — Disparition ou perte de données

La perte de données médicales, qu'elle soit accidentelle (panne, erreur humaine) ou malveillante (ransomware), interromprait le suivi médical des patients concernés ; un impact

potentiellement grave si l'information n'est disponible nulle part ailleurs. La vraisemblance dépend largement des pratiques de sauvegarde de CloudSecure, qui ne sont pas détaillées dans le document fourni et devront être vérifiées lors de l'audit final. C'est d'ailleurs un axe d'amélioration à souligner : le document ne mentionne aucune politique de sauvegarde ou de plan de continuité d'activité.

Synthèse : le traitement présente un niveau de risque global **modéré à élevé**, essentiellement du fait de la nature sensible des données de santé, mais atténué par les mesures de sécurité déjà en place chez X-corp (chiffrement AES-256, 2FA, RBAC, pseudonymisation). Les recommandations principales issues de cette DPIA sont : clarifier la finalité « personnalisation des conseils de santé », mettre en place une journalisation des accès aux dossiers médicaux, et documenter les pratiques de sauvegarde de CloudSecure.

Jour 4

Jour 4 — Simulation de violation de données : cas RetailCo

1. Scénario

Un matin, l'équipe technique de X-corp détecte une activité inhabituelle sur les serveurs hébergeant DataManage : plusieurs requêtes automatisées ont exploité une faille dans une API interne, permettant à un tiers non autorisé d'extraire une partie de la base de données clients de RetailCo. L'incident touche environ **15 000 enregistrements clients** (sur les 800 000 gérés pour RetailCo), incluant noms, adresses, emails, numéros de téléphone et historique d'achats, mais **pas** de données bancaires, celles-ci n'étant pas gérées par DataManage. L'anomalie est repérée grâce à une alerte du système de détection d'intrusion, deux jours après le début de l'extraction.

2. Détection et qualification

Détection : L'incident est repéré par le système de détection d'intrusion (IDS) de X-corp, qui remonte une alerte suite à un volume de requêtes anormal sur l'API interne de DataManage. L'équipe technique confirme l'extraction non autorisée après analyse des logs, deux jours après le début réel de l'incident ; un délai qui souligne l'importance d'une surveillance continue plutôt que ponctuelle.

Qualification : Au sens du RGPD, une violation de données est définie comme une atteinte à la sécurité entraînant, de manière accidentelle ou illicite, la destruction, la perte, l'altération, la divulgation ou l'accès non autorisé à des données personnelles. Ici, il s'agit clairement d'une **violation de confidentialité** : des données ont été consultées et extraites par un tiers non autorisé, sans qu'il y ait pour autant destruction ou altération des données originales (les violations d'intégrité et de disponibilité ne sont donc pas concernées dans ce scénario).

Cette qualification déclenche immédiatement les obligations prévues par les articles 33 et 34 du RGPD, dont l'évaluation du risque (*l'étape suivante*) déterminera l'étendue exacte.

3. Évaluation du risque

Pour déterminer les obligations de notification, il faut évaluer si la violation engendre un **risque élevé** pour les droits et libertés des personnes concernées. Plusieurs critères entrent en jeu.

Nature des données exposées : les données concernées (noms, adresses, emails, téléphone, historique d'achats) sont des données personnelles courantes, mais **pas** des données sensibles au sens de l'article 9 (pas de santé, pas d'opinions politiques, etc.) et **pas** de données bancaires. Le risque est donc moindre que si l'incident avait touché HealthMed.

Volume et facilité d'identification : 15 000 personnes sont concernées, et les données permettent de les identifier directement (nom + coordonnées). Le risque de préjudice reste réel : notamment un risque de phishing ciblé ou de démarchage frauduleux exploitant l'historique d'achats. Mais il est **limité** comparé à un vol de données de santé ou financières.

Conséquences potentielles pour les personnes : usurpation d'identité peu probable avec ces seules données, mais risque de spam, de tentatives de phishing personnalisées (« nous avons vu que vous avez acheté X, cliquez ici... »), ou de perte de confiance envers RetailCo.

Conclusion de l'évaluation : le risque est jugé **modéré**, mais **non négligeable** du fait du volume de personnes touchées et du caractère identifiant des données. Il ne s'agit pas d'un risque « élevé » au sens strict (pas de données sensibles), mais suffisant pour déclencher la notification à la CNIL - la question de la communication directe aux personnes concernées, elle, dépendra de ce seuil de gravité, comme on le verra en *partie 5*.

4. Notification à la CNIL

Puisque la violation présente un risque avéré pour les personnes concernées (même s'il n'est pas qualifié d'« élevé »), X-corp - en tant que sous-traitant de RetailCo - a l'obligation de notifier RetailCo (responsable de traitement) sans délai après avoir pris connaissance de la violation. C'est ensuite **RetailCo**, en tant que responsable de traitement, qui doit notifier la CNIL dans un délai maximal de **72 heures** après en avoir eu connaissance. Cette distinction est importante : le RGPD place l'obligation de notification à la CNIL sur le responsable de traitement, mais le sous-traitant (ici X-corp) doit l'alerter immédiatement pour lui permettre de respecter ce délai.

La notification à la CNIL doit contenir, a minima :

- **La nature de la violation** : accès non autorisé à des données via l'exploitation d'une faille sur une API interne.
- **Les catégories et le nombre approximatif de personnes concernées** : environ 15 000 clients de RetailCo.
- **Les catégories et le volume approximatif de données concernées** : noms, adresses, emails, téléphone, historique d'achats.
- **Le nom et les coordonnées du DPO** ou d'un point de contact pour obtenir plus d'informations.
- **Les conséquences probables** de la violation (risque de phishing ciblé, démarchage frauduleux).
- **Les mesures prises ou proposées** pour remédier à la violation et en limiter les effets négatifs (*voir partie 6*).

Si l'ensemble de ces informations n'est pas disponible immédiatement, le RGPD autorise une notification progressive, en plusieurs fois, à condition de ne pas dépasser un délai raisonnable pour la compléter.

5. Communication aux personnes concernées

La communication directe aux personnes concernées n'est obligatoire que lorsque la violation est susceptible d'engendrer un **risque élevé** pour leurs droits et libertés (article 34 du RGPD). Dans notre scénario, l'évaluation menée en *partie 3* a conclu à un risque **modéré**, sans données sensibles ni financières exposées ; cette communication directe n'est donc **pas strictement obligatoire** au sens légal.

Cela dit, dans une logique de transparence et de gestion de la confiance client (au-delà de la seule obligation légale), il serait recommandé que RetailCo informe tout de même les 15 000 clients concernés, notamment parce que le risque de phishing ciblé identifié plus haut peut être atténué efficacement par une simple mise en garde. Cette communication, si elle est envoyée, devrait :

- Être rédigée en langage clair, sans jargon juridique ou technique.
- Décrire la nature de la violation et les données concernées.
- Recommander des mesures de vigilance concrètes (méfiance face à des emails ou appels inhabituels se présentant comme venant de RetailCo, vérification de l'expéditeur avant tout clic).
- Fournir un point de contact pour toute question.

Un envoi par email serait le canal le plus cohérent, puisque c'est justement l'une des données exposées et le canal habituel de communication avec ces clients.

6. Mesures correctives

Mesures immédiates (réaction à chaud, dans les heures/jours suivant la détection) :

- Correction de la faille exploitée sur l'API interne (patch de sécurité, revue du code concerné).
- Révocation et rotation des clés d'accès ou tokens API potentiellement compromis.
- Analyse complète des logs pour confirmer l'étendue exacte de l'extraction (nombre exact de personnes touchées, données précises).
- Renforcement temporaire de la surveillance sur l'ensemble des API de X-corp, le temps de s'assurer qu'aucune autre faille similaire n'existe.

Mesures de fond (pour éviter la récurrence, à plus long terme) :

- Mise en place d'audits de sécurité réguliers des API, notamment des tests d'intrusion périodiques plutôt que ponctuels.
- Renforcement du système de détection d'intrusion pour réduire le délai de détection (ici, deux jours se sont écoulés avant l'alerte).
- Formalisation d'un **plan de réponse aux incidents** documenté, avec des rôles clairement définis (qui alerte qui, dans quel délai, avec quel contenu) ; un point d'autant plus pertinent que le document initial mentionnait déjà des « lacunes dans le processus de réponse » lors de la précédente fuite de données.
- Sensibilisation des équipes techniques à la sécurisation des API dès la conception (*security by design*), en cohérence avec le principe d'intégrité et de confidentialité vu en *Jour 1*.

Cette dernière recommandation fait particulièrement écho à l'incident réel mentionné dans le document de X-corp : la fuite passée avait déjà révélé des lacunes dans le processus de réponse, ce qui rend d'autant plus pertinent de formaliser une procédure claire pour éviter qu'un même type de faiblesse organisationnelle ne se reproduise.

Jour 5

Jour 5 — Audit de conformité RGPD : X-corp

1. Méthodologie

Cet audit s'appuie sur quatre étapes complémentaires menées au cours de la semaine : l'analyse des concepts clés du RGPD appliqués au contexte de X-corp (*Jour 1*), l'élaboration du registre des traitements couvrant les trois activités principales de l'entreprise ; RetailCo, HealthMed, EduLearn (*Jour 2*). La réalisation d'une DPIA sur le traitement le plus sensible, celui des données de santé pour HealthMed (*Jour 3*), et la simulation de la gestion d'une violation de données sur le cas RetailCo (*Jour 4*). Cette approche progressive permet de croiser une vision théorique, une vision documentaire et une vision opérationnelle de la conformité de X-corp.

2. Points forts identifiés

L'audit révèle que X-corp dispose déjà d'un socle de conformité solide sur plusieurs aspects. Sur le plan technique, l'entreprise applique des mesures de sécurité cohérentes avec le principe d'intégrité et de confidentialité : chiffrement AES-256 des données en transit et au repos, authentification à deux facteurs pour l'accès aux systèmes internes, contrôle d'accès basé sur les rôles (RBAC), et pseudonymisation des données sensibles. Ces mesures, retrouvées de façon transversale dans les trois traitements audités, témoignent d'une approche de sécurité intégrée plutôt que ponctuelle.

Sur le plan organisationnel, X-corp a nommé un **DPO** chargé de superviser la conformité, ce qui constitue une obligation légale correctement respectée compte tenu du volume et de la sensibilité des données traitées. L'entreprise réalise également une **DPIA pour chaque nouveau produit** avant son lancement ; une pratique qui va au-delà du strict minimum légal, puisqu'elle anticipe les risques dès la conception plutôt que de les traiter a posteriori. Enfin, la politique de conservation des données est différenciée selon la sensibilité de chaque traitement (5 ans pour RetailCo, 10 ans pour HealthMed, 2 ans pour EduLearn) et fait l'objet d'une revue régulière tous les 2 ans, ce qui démontre une prise en compte réelle du principe de limitation de la conservation vu en *Jour 1*.

3. Points de non-conformité et axes d'amélioration

Cette partie regroupe les fragilités identifiées au fil de l'audit, classées par thème et assorties d'un niveau de priorité.

Gestion du consentement marketing — priorité haute

Le document signale des difficultés récurrentes à gérer et documenter le consentement des utilisateurs pour les campagnes réalisées via AutoMail. Or, le consentement étant la base légale principale utilisée par X-corp pour l'ensemble de ses traitements, son absence de traçabilité fragilise la conformité de plusieurs traitements à la fois, et non d'un seul. C'est un point prioritaire car il touche au fondement même de la licéité des traitements.

Transferts de données hors UE — priorité haute

L'élaboration du registre des traitements (*Jour 2*) a révélé une zone d'ombre commune aux trois traitements audités : l'absence d'information sur la localisation des serveurs de

CloudSecure, partenaire d'hébergement. Sans cette information, il est impossible de vérifier si des données quittent l'Union européenne et, le cas échéant, si les garanties appropriées (clauses contractuelles types, décision d'adéquation) sont en place.

Processus de réponse aux incidents — priorité haute

La simulation menée en *Jour 4* s'appuie sur un incident réel : une fuite de données ayant déjà exposé 2 000 enregistrements clients il y a un an, avec des lacunes reconnues dans le processus de réponse. Un an après, rien n'indique qu'un plan de réponse aux incidents formalisé ait été mis en place, ce qui expose X-corp à un risque de récurrence et à un manquement à l'obligation de notification sous 72h.

Volume des demandes de droit d'accès — priorité moyenne

Avec 50 à 100 demandes de droit d'accès reçues chaque mois, X-corp gère un volume conséquent sans que le document ne précise l'existence d'un outil ou processus dédié. Ce flux régulier constitue un risque opérationnel : tout retard dans le traitement de ces demandes au-delà du délai légal d'un mois constituerait une non-conformité.

Finalités insuffisamment délimitées — priorité moyenne

La DPIA réalisée en *Jour 3* a mis en évidence une ambiguïté sur la finalité « personnalisation des conseils de santé » pour HealthMed, sans distinction claire entre recommandation automatisée et avis d'un professionnel de santé. Cette imprécision fragilise le respect du principe de limitation des finalités.

Continuité d'activité et sauvegardes — priorité moyenne

Toujours identifiée lors de la DPIA, l'absence de politique de sauvegarde ou de plan de continuité documentée constitue un risque, notamment pour le traitement HealthMed où une perte de données pourrait interrompre un suivi médical.

4. Plan d'action recommandé

Court terme (0-3 mois)

- Documenter la localisation exacte des serveurs CloudSecure et vérifier l'existence de garanties appropriées en cas de transfert hors UE (clauses contractuelles types ou décision d'adéquation).
- Formaliser un plan de réponse aux incidents, avec des rôles et délais clairement définis (qui alerte qui, sous quel délai, avec quel contenu), en s'appuyant directement sur les enseignements de la simulation menée en *Jour 4*.
- Mettre en place un outil ou un processus dédié de gestion et de traçabilité du consentement pour les campagnes AutoMail, incluant un mécanisme de retrait aussi simple que le don du consentement initial.

Moyen terme (3-6 mois)

- Clarifier avec HealthMed la nature exacte de la finalité « personnalisation des conseils de santé », afin de déterminer si un profilage automatisé est en jeu et si cela nécessite des garanties supplémentaires.
- Auditer et documenter la politique de sauvegarde et de continuité d'activité de CloudSecure pour l'ensemble des traitements, en priorité pour HealthMed.

- Évaluer si le volume de demandes de droit d'accès (50 à 100/mois) nécessite un outil dédié ou un renforcement des effectifs en charge de leur traitement, afin de garantir un respect systématique du délai légal d'un mois.

Long terme (6-12 mois)

- Mettre en place des audits de sécurité réguliers des API et systèmes internes (tests d'intrusion périodiques), au-delà des DPIA déjà réalisées avant chaque lancement de produit.
- Intégrer une revue de conformité RGPD systématique dans le cycle de développement de chaque nouveau produit, en amont de la DPIA elle-même (approche *privacy by design*).

5. Conclusion générale

Cet audit de X-corp dresse le portrait d'une entreprise consciente des enjeux de protection des données, dotée d'un socle technique et organisationnel déjà solide : DPO nommé, DPIA systématiques, chiffrement, authentification renforcée et contrôle d'accès par rôles constituent une base de conformité réelle et non de façade.

Cependant, l'audit révèle aussi que cette maturité technique n'est pas encore pleinement relayée par des processus organisationnels documentés : la gestion du consentement, la traçabilité des transferts de données, et la réponse aux incidents restent des zones de fragilité, comme l'a confirmé la simulation de violation menée en *Jour 4* en écho à un incident réel déjà survenu chez X-corp. La conformité RGPD n'est jamais un état figé mais un processus continu - le plan d'action proposé vise précisément à transformer les bonnes pratiques déjà en place en un système documenté, traçable et pérenne, seul à même de garantir une conformité durable face à l'évolution des traitements et des risques.